SECCIÓN 6.7

Secuencia operativa de respuesta inicial y toma de decisiones con incertidumbre

Temas de esta sección:

- 7 pasos de la secuencia de respuesta inicial
- Decidir con evidencia incompleta: documentar limitaciones y actuar proporcional al riesgo
- Matriz práctica: evidencia × impacto → decisión
- Cuándo cerrar, monitorear, validar, escalar o contener
- Caso integrador 1: endpoint de Finanzas
- Caso integrador 2: cuenta comprometida probable
- Caso integrador 3: servidor de pagos con web shell

6.7 | La secuencia de respuesta inicial: 7 pasos

Una guía para ordenar la respuesta — no una receta rígida:

1	**CONFIRMAR LO BÁSICO**	Qué alerta · Qué activo · Qué usuario · Qué fuente · A qué hora · ¿Permitido o bloqueado?
2	**REVISAR EVIDENCIA MÍNIMA**	¿Qué comportamiento real ocurrió? · ¿Actividad posterior? · ¿Persistencia? · ¿Otros hosts afectados?
3	**EVALUAR CRITICIDAD E IMPACTO**	¿El activo es crítico? · ¿Afecta clientes o pagos? · ¿Cuenta privilegiada? · ¿La contención interrumpe operación?
4	**PRESERVAR LO INDISPENSABLE**	Alerta · Process tree · Command line · Hash · IPs · Timestamps · Persistencia · Reglas/tokens si aplica
5	**DECIDIR SEGÚN PLAYBOOK**	¿Qué puede hacer el SOC? · ¿Qué requiere autorización? · ¿Qué equipo debe participar?
6	**ESCALAR / VALIDAR / CONTENER**	Según evidencia, criticidad e impacto. Documentar limitaciones si la evidencia es incompleta.
7	**COMUNICAR PRÓXIMOS PASOS**	Qué se observó · Qué se hizo · Qué falta · Qué riesgo queda · Quién debe actuar.

En casos críticos, algunos pasos ocurren en paralelo: mientras se preserva, también se escala. Mientras se valida con negocio, se prepara la contención.

6.7 | Decidir con evidencia incompleta

No esperar certeza absoluta. Documentar las limitaciones y actuar proporcional al riesgo disponible:

Qué documentar cuando falta evidencia

- Qué fuentes no estaban disponibles (sin EDR, sin proxy)
- Qué validaciones no se pudieron completar
- Qué preguntas siguen abiertas
- Por qué se tomó la decisión con la información disponible
- Cuál sería la próxima evidencia que cambiaría la decisión
- Qué se monitoreará mientras se espera más información

Frases correctas para comunicar incertidumbre

'No se identificó evidencia de actividad maliciosa en las fuentes revisadas.'

'La actividad es compatible con posible...'

'No se pudo validar... debido a falta de visibilidad.'

'Se recomienda ampliar revisión si la actividad se repite.'

EVITAR: 'No pasó nada.' / 'Es falso positivo.' / 'Es C2.' — sin evidencia que lo respalde.

La incertidumbre se documenta, no se oculta. Una decisión bien documentada con limitaciones explícitas es más valiosa que una conclusión inventada.

Una forma práctica de decidir qué hacer según la evidencia disponible y el impacto potencial:

Evidencia	Impacto	Decisión recomendada	Ejemplo
DÉBIL	BAJO	**Documentar, monitorear o pedir validación**	*DNS raro consultado una vez, sin conexión posterior, host no crítico.*
DÉBIL	ALTO	**Escalar con limitaciones o validar prioritariamente**	*Activo crítico con poca evidencia → validar rápido. Si no se puede, escalar preventivamente.*
FUERTE	BAJO	**Contener según playbook o escalar según procedimiento**	*Malware activo en endpoint de usuario. Playbook permite aislamiento. Activo no crítico.*
FUERTE	ALTO	**Escalamiento urgente, preservación y contención coordinada**	*Web shell + ejecución + servidor de pagos → IR, apps, infra, negocio de forma inmediata.*

6.7 | Cuándo cerrar, monitorear, validar, escalar o contener

Cinco decisiones posibles en respuesta inicial — cada una requiere justificación:

CERRAR	Cuándo: Actividad benigna, esperada o bloqueada sin señales adicionales. Ticket válido, usuario técnico, host en alcance.	*Documentar: Qué se revisó, qué lo valida, por qué no hay riesgo.*
MONITOREAR	Cuándo: Evidencia insuficiente para escalar pero tampoco suficiente para cerrar. Seguimiento sin urgencia inmediata.	*Documentar: Qué se observó, qué falta, cuándo revisar de nuevo.*
PEDIR VALIDACIÓN	Cuándo: El contexto operativo puede cambiar la interpretación. Usuario, dueño del sistema o IT pueden aclarar.	*Documentar: Qué ocurrió, qué se pregunta, a quién y por qué.*
ESCALAR	Cuándo: Evidencia indica riesgo relevante, posible compromiso o necesidad de análisis forense avanzado.	*Documentar: Qué se observó, qué hipótesis, qué evidencia, qué se recomienda.*
CONTENER	Cuándo: Hay evidencia suficiente y autorización (o urgencia extrema) para reducir la capacidad de la amenaza.	*Documentar: Qué acción, quién autorizó, qué puede perderse y por qué se actúa.*

Cada decisión requiere justificación documentada. No cerrar sin evidencia. No escalar sin contexto. No contener sin considerar el impacto operativo.

6.7 | Tres casos integradores: secuencia completa

Aplicando la secuencia de 7 pasos a los tres casos del módulo:

ENDPOINT FINANZAS	CUENTA COMPROMETIDA	WEB SHELL — PAGOS
1. FIN-LAP-022 / finanzas.paz / EDR / Allowed 2. WINWORD→PS -enc + update.exe + tarea + C2 periódico 3. Endpoint de usuario — impacto moderado 4. Process tree, hash, tarea, conexión, correo origen 5. Playbook: aislar endpoints con malware activo 6. Escalar IR + recomendar aislamiento + buscar alcance 7. 'Secuencia compatible con ejecución inicial + C2. Recomendamos contención y revisión de alcance.'	1. legal.romero / Impossible travel / identidad / MFA ok 2. Device unknown + regla reenvío + OAuth + 1,200 archivos 3. Cuenta con info legal sensible — impacto alto 4. Login, regla, OAuth (permisos, timestamp), descargas 5. Coordinar con identidad / IR 6. Escalar identidad + revocar sesiones + revisar OAuth 7. 'Compatible con posible compromiso. Cuenta accede a info sensible. Se recomienda revocación y revisión de reglas.'	1. WEB-PAY-01 / portal de pagos / WAF+EDR 2. Injection allowed + w3wp→cmd→whoami + shell.aspx 3. Servidor productivo crítico — impacto muy alto 4. WAF logs, EDR tree, archivo, requests, IP origen 5. NO actuar sin coordinación (corte de pagos) 6. Escalar urgente: IR+apps+infra+negocio + regla WAF 7. 'Posible ejecución remota. Sistema de pagos activo. Preservada evidencia. Evaluando contención coordinada.'